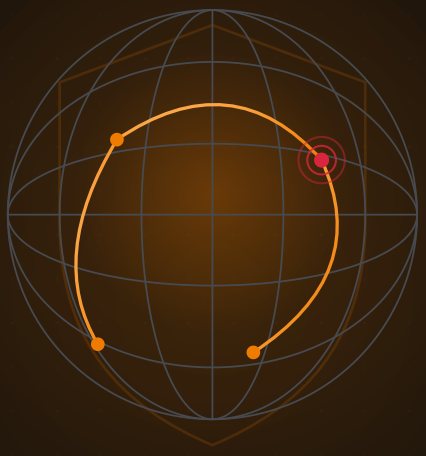


# THREAT PULSE

## ÉDITION MAROC

WEEKLY CYBER THREAT BRIEFING · MOROCCO

SEMAINE DU 26 OCTOBRE AU 1ER NOVEMBRE 2026

Au sommaire : la faille **GitLab** de gravité maximale désormais exploitée, l'opération **INTERPOL** contre la cybercriminalité en Afrique, et une faille **Drupal Commerce** contre les boutiques en ligne.

Bienvenue dans **Threat Pulse — Édition Maroc**, votre point hebdomadaire, en langage clair, sur les cybermenaces qui concernent les entreprises marocaines. Cette semaine, aucun incident marocain nouveau n'a pu être confirmé ; la menace à retenir est une faille de gravité maximale dans **GitLab**, désormais exploitée, qui touche les serveurs de code de nombreuses entreprises. Côté mondial, une faille de **Drupal Commerce** vise aussi les boutiques en ligne.

## EN UN COUP D'ŒIL · CETTE SEMAINE

**10/10**
Gravité maximale de la faille GitLab (CVE-2026-97229), exploitée dans la nature
IT-CONNECT · BLEEPINGCOMPUTER · 14–30 OCT. 2026

**~2 800**
serveurs GitLab (édition communautaire) exposés sur Internet (Shadowserver)
BLEEPINGCOMPUTER · 30 OCT. 2026

**1 462**
suspects arrêtés dans 21 pays lors de l'opération INTERPOL « Serengeti III »
THE HACKER NEWS · 22 OCT. 2026

## LA MENACE PHARE DE LA SEMAINE

MENACE MONDIALE · EXPLOITATION CONFIRMÉE (CISA) · 29 OCTOBRE 2026

### GitLab : une faille de gravité maximale est maintenant exploitée

NIVEAU **CRITIQUE**

**10/10** · exploitation confirmée par la CISA · correctif disponible

**Que se passe-t-il ?**

GitLab, outil très utilisé pour stocker et construire du code, a corrigé le 12 octobre la faille **CVE-2026-97229** : un attaquant **sans identifiant** peut **exécuter du code à distance** sur le serveur via une configuration de pipeline piégée. Le 29 octobre, l'agence américaine **CISA** l'a ajoutée à son catalogue des failles **exploitées dans la nature**, et GitLab dit avoir observé des tentatives d'attaque.

**Qui est concerné ?**

Les entreprises qui **hébergent elles-mêmes GitLab** (versions avant **19.2.8, 19.3.5 ou 19.4.2**), souvent leur DSI ou un prestataire de développement. **GitLab.com** est déjà corrigé. Shadowserver recense près de **2 800** serveurs de l'édition communautaire exposés sur Internet. Nous n'avons pas pu vérifier de bulletin DGSSI dédié à cette faille cette semaine.

**Pourquoi c'est important**

Un serveur GitLab contient le **code source** et souvent des **clés et mots de passe** qui ouvrent d'autres systèmes. Le correctif existe depuis plus de deux semaines : le risque vient des serveurs **pas encore mis à jour**. Si le vôtre était exposé avant correction, considérez ces secrets comme potentiellement compromis.

### ! À faire cette semaine

- ✓ Demandez à votre équipe ou prestataire si vous **hébergez GitLab** et passez à **19.2.8, 19.3.5 ou 19.4.2** (ou plus récent) sans attendre.
- ✓ Si le serveur était accessible depuis Internet : **changez les clés et mots de passe** qu'il contient et vérifiez ses journaux.

## AUTRES MENACES À CONNAÎTRE

MOYEN

### Maroc : pas d'autre incident vérifié cette semaine

Nous n'avons trouvé **aucun incident marocain nouveau et confirmé** sur la période. Les revendications de fuites visant des organismes marocains, comme celle contre la **CNOPS** (avril 2026), restent **non confirmées officiellement** et ne sont pas de cette semaine. Les outils de développement, eux, sont rarement inventoriés par les directions.

**À retenir : ajoutez vos outils de développement (GitLab, dépôts de code) à votre inventaire des systèmes à mettre à jour.**

MOYEN

### Afrique : INTERPOL démantèle près de 11 000 réseaux criminels

L'opération **Serengeti III** (29 juin–31 août, annoncée le 22 octobre) a mené à **1 462 arrestations** dans 21 pays, la neutralisation de **10 909 réseaux** et la récupération de plus de **105 M$**. Le Maroc n'est pas dans la liste des pays, mais les fraudes visées (hameçonnage, fraude à l'e-mail professionnel, faux investissements) sont celles qui touchent aussi les entreprises marocaines.

**À retenir : un virement « urgent » demandé par e-mail se confirme toujours par un autre canal (téléphone).**

ÉLEVÉ

### Menace mondiale : une faille de Drupal Commerce exploitée contre des boutiques en ligne

Drupal a alerté le 30 octobre sur **CVE-2026-118539** (module **Commerce Core**) : un contournement des contrôles d'accès par un attaquant **sans identifiant**, **déjà exploité** selon l'avis de Drupal. Le module sert plus de **42 000** sites. Correctifs : **3.3.13** (branche 3.x) ou **8.x-2.41** ; Drupal recommande aussi de vérifier les commandes pour repérer des anomalies.

**À retenir : si vous vendez en ligne, demandez à votre prestataire web si la boutique repose sur Drupal Commerce.**

### Le coin conformité — DGSSI & CNDP

Les **bulletins d'alerte de la DGSSI** (cadre de la **loi 05-20** et de la **DNSSI**) sont des recommandations à suivre vite, y compris pour les outils « de l'ombre » comme un serveur de code. Un dépôt de code contient souvent des **identifiants et des données personnelles de test ou réelles** : la **loi 09-08**, sous le contrôle de la **CNDP**, impose de protéger ces données, d'où l'intérêt de **noter ce que vous avez corrigé et quand**. Si des données ont pu être exposées, évaluez vos obligations auprès de la CNDP.

### Votre check-list en 3 minutes

- ✓ **GitLab** — si vous l'hébergez, passez à 19.2.8, 19.3.5 ou 19.4.2 (CVE-2026-97229) et changez les clés qu'il contient.
- ✓ **Boutique en ligne** — si elle utilise Drupal Commerce, passez à 3.3.13 ou 8.x-2.41 et vérifiez les commandes récentes.
- ✓ **Inventaire** — listez aussi vos outils de développement et sites gérés par des prestataires.
- ✓ **Virements** — confirmez par téléphone toute demande de paiement « urgente » reçue par e-mail.

Threat Pulse — Édition Maroc est fourni par DPG-Cyber à titre de sensibilisation générale et ne constitue pas un conseil de sécurité ou juridique spécifique. Informations issues de sources publiques réputées au 2 novembre 2026.

AU-DELÀ DES GROS TITRES

# Pourquoi une surveillance continue change tout

Chaque menace de ce numéro a un point commun : les dégâts surviennent dans le **silence entre l'intrusion et le moment où quelqu'un s'en aperçoit**. Ce qui limite les dommages, c'est une surveillance continue qui corrèle les signaux, repère l'intrusion tôt et réagit avant qu'un point d'entrée ne devienne une crise.

**247 jours**

Temps moyen pour détecter *et* contenir une violation

IBM COST OF A DATA BREACH 2026

**$4,99M**

Coût moyen mondial d'une violation de données

IBM COST OF A DATA BREACH 2026

## CE QUE FAIT UNE SURVEILLANCE CONTINUE

### Voir l'ensemble

Un SIEM rassemble et corrèle l'activité de vos systèmes : les comportements anormaux ressortent au lieu de se noyer dans le bruit.

### Veiller 24h/24

Les attaques n'ont pas d'horaires de bureau. Un SOC, ce sont de vraies personnes qui surveillent jour et nuit, week-ends compris.

### Connaître les dernières tactiques

Le renseignement sur les menaces — comme la faille GitLab de ce numéro — alimente la détection.

### Agir, pas seulement alerter

Les alertes sont triées et investiguées par des analystes qui interviennent tôt, transformant un incident potentiel en non-événement.

## ACTION CLIENT DE LA SEMAINE

CETTE SEMAINE

### Mettez à jour GitLab et vos outils de développement

Si vous hébergez GitLab, passez à **19.2.8, 19.3.5 ou 19.4.2** (**CVE-2026-97229**), puis changez les clés et mots de passe qu'il contient. Faites de même pour Drupal Commerce si votre boutique l'utilise.

BON RÉFLEXE

### Testez vos sauvegardes hors ligne

Une sauvegarde **déconnectée du réseau** est votre filet de sécurité si un serveur est piraté. Faites chaque trimestre un **essai de restauration** réel, chronométrez-le et notez ce qui manque.

C'est le travail discret, au quotidien, derrière les **services SIEM & SOC de DPG-Cyber** — la même surveillance qui transforme des gros titres comme ceux-ci en non-événements pour les entreprises que nous protégeons. Curieux de savoir ce que cela donnerait chez vous ? Écrivez-nous, sans engagement, à **hello@dpg-cyber.com**.